

ACTIVITY 8

Express + MongoDB + Auth

branch name: activity-8-nodejs

Activity 8 - Add Auth to your To Dos App



Start with your working Todos REST API and progressively add auth + RBAC. Six tasks.

Task 1 - Refactor to MVC - Split your flat `server.js` into `models/ToDo.js`, `controllers/todoController.js`, `routes/todoRoutes.js`. `server.js` becomes a slim entry point.

Task 2 - Add a User model - Create `models/User.js` with `{ email, passwordHash, role }`. `npm install bcrypt jsonwebtoken`. Add `JWT_SECRET` to `.env`.

Task 3 - **POST /register** - `controllers/authController.js` + `routes/authRoutes.js`. Hash password with `bcrypt`, create the user. Return 201 with `{ id, email }`. 409 on duplicate email.

Activity 8 - Add Auth to your To Dos App

Task 4 - POST /login + JWT - Verify password with `bcrypt.compare`. Sign a JWT containing `{ sub: user._id, role }` with `expiresIn: '1h'`. Return `{ token }`.

Task 5 - Protect /todos + scope to owner - Create `middleware/requireAuth.js`. Add `owner: ObjectId ref User` to the `Todo` schema. Apply `requireAuth` to all `/todos` routes. On create, set `owner = req.user.id`. On list/read/update/delete, filter by `owner`.

Task 6 - Admin RBAC - Create `middleware/requireRole.js`. Add `DELETE /admin/todos/:id` protected by `requireRole('admin')`. Admins can delete any todo, regardless of owner.